

Documento de consolidación y verificación de las ediciones vigentes (a septiembre de 2025) de las normas ISO/IEC más relevantes para la gestión de la seguridad, la ciberseguridad, la privacidad y la inteligencia artificial. Incluye una tabla comparativa con los cambios significativos y un checklist de transición para auditar y adaptar el sistema de gestión.

Descargo de Responsabilidad: documento vivo y sujeto a cambios. Disculpas si encuentran algún error o dato que no haya sido correctamente actualizado o modificado. Se agradecen sugerencias y comentarios.

Normas ISO de Seguridad de la Información, Ciberseguridad e IA

Listado actualizado, cambios clave e implicaciones prácticas

(Septiembre 2025)

Autor: José Carlos Almansa Moreno
Head of Compliance & Cybersecurity
GRC Consultant
Fecha: 04/09/2025

1. Alcance y criterios de actualización

Se han revisado una a una las normas citadas en la discusión original y en los comentarios posteriores.

Se contrasta su última edición publicada y, cuando aplica, enmiendas y sustituciones y retiradas (ej.: 24762 retirada; referencia correcta 27031:2025).

Este ejercicio nos ayuda a traducir los cambios a acciones operativas verificables de auditoría.

El foco práctico es doble:

- (i) *qué ha cambiado.*
- (ii) *cómo impacta* en el SGSI/SGIA, la operación y la evidencia de auditoría.

2. Tabla comparativa de ediciones y cambios

Resumen de ediciones vigentes, cambios frente a versiones anteriores e impacto operativo.

Norma	Edición vigente	Resumen del cambio	Impacto práctico
ISO/IEC 27001 — Requisitos de SGSI Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de la seguridad de la información	2022 + Amd 1:2024	Enmienda 2024: considerar cambio climático en el contexto (4.1) y partes interesadas.	Actualizar análisis de contexto, registro de riesgos y oportunidades.
ISO/IEC 27002 — Guía de controles Seguridad de la información, ciberseguridad y protección de la privacidad: controles de seguridad de la información	2022	Estructura por temas y atributos; 93 controles. Sin cambios desde 2022.	Mantener mapeo 27001 Anexo A ↔ 27002.

Norma	Edición vigente	Resumen del cambio	Impacto práctico
ISO/IEC 27005 — Gestión de riesgos de SI Seguridad de la información, ciberseguridad y protección de la privacidad: Orientación sobre la gestión de riesgos de seguridad de la información	2022	Alineación con 31000; énfasis en apetito de riesgo.	Sincronizar metodología con 31000 y 27001.
ISO/IEC 27032 — Directrices de ciberseguridad	2023	2ª edición: taxonomía y alcance actualizados.	Alinear con políticas corporativas y NIS2.
ISO/IEC 27017 — Seguridad en servicios cloud	2015 (vigente)	Sin revisión publicada.	Mantener controles complementarios proporcionados.
ISO/IEC 27018 — PII en nubes públicas	2025	Nueva edición alineada con 27002:2022; roles y Anexo B actualizados.	Actualizar cláusulas con CSP/encargados.
ISO/IEC 27701 — PIMS (gestión de privacidad)	2019 (vigente)	Revisión en curso no publicada.	Mantener integración con RGPD y con 27001.
ISO/IEC 27019 — Seguridad para utilities (energía)	2024	Alineada con 27002:2022; cubre OT/ICS.	Actualizar controles de operaciones energéticas.
ISO/IEC 27033 — Seguridad de redes	1–6: 2010–2016; 7: 2023	Nueva Parte 7 (virtualización/SDN/NFV).	Revisar segmentación y funciones virtualizadas.
ISO/IEC 27034 — Seguridad de aplicaciones	Partes 1–3 (2011/2015/2018)	Sin cambios recientes.	Evidenciar S-SDLC y gobierno de seguridad.
ISO/IEC 27035-1 — Gestión de incidentes — Principios	2023	Proceso y funciones actualizados.	Revisar política IR y KPIs/MTTR/MTTD.

Norma	Edición vigente	Resumen del cambio	Impacto práctico
ISO/IEC 27035-2 — Gestión de incidentes — Preparación	2023	Énfasis en preparación y lecciones aprendidas.	Ejercicios y mejora continua.
ISO/IEC 27035-3 — Gestión de incidentes — Operación	2020	Vigente.	Runbooks, evidencias y coordinación forense.
ISO/IEC 27037 — Evidencia digital — Identificación y preservación	2012	Vigente.	Cadena de custodia y procedimientos periciales.
ISO/IEC 27038 — Redacción/expurgo seguro de documentos	2014	Vigente.	Controlar expurgo y enmascaramiento en documentos.
ISO 22301 — SG de Continuidad de Negocio (BCMS)	2019	Vigente.	BIA, estrategia, pruebas y aprendizaje organizacional.
ISO/IEC 27031 — Preparación TIC para la continuidad	2025	Nueva edición que sustituye 27031:2011 y consolida retirada de 24762:2008.	Alinear DR/BCP TIC con 22301; pruebas técnicas.
ISO 31000 — Gestión del riesgo — Directrices	2018	Vigente.	Coherencia entre dominios de riesgo.
ISO 31073 — Vocabulario de gestión del riesgo	2022	Sustituye a Guía ISO 73:2009.	Actualizar glosario corporativo.
ISO/IEC 38500 — Gobierno de TI	2024	Revisión mayor; moderniza principios y responsabilidades.	Actualizar gobierno, reporting y supervisión.
ISO/IEC 42001 — Sistema de Gestión de IA (AIMS)	2023	Primera edición.	Definir alcance, objetivos, roles y mejora continua.
ISO/IEC 23894 — Gestión de	2023	Primera edición.	Integrar riesgos

Norma	Edición vigente	Resumen del cambio	Impacto práctico
riesgos de IA			técnicos, éticos y de seguridad.
ISO/IEC 22989 — Conceptos y terminología de IA	2022	Primera edición y (Ratificada por la Asociación Española de Normalización en agosto de 2023.)	Actualizar definiciones para políticas y contratos.
ISO/IEC 42005 — Evaluación de impacto de sistemas de IA	2025	Nueva norma: impactos a personas/sociedad; transparencia y no discriminación.	Incorporar evaluación de impacto ético-social.

3. Top 7 cambios que se deben de tener en cuenta

- ISO/IEC 27018:2025 — PII en nubes públicas: alinea controles con 27002:2022 y actualiza roles y anexos:
 - Alineación con ISO/IEC 27002:2022; mayor claridad en roles (responsable/encargado/subencargado).
 - Más foco en logs, cifrado, portabilidad y ejercicio de derechos.
 - Acción: actualizar cláusulas con proveedores cloud y evidencias de controles.
- ISO/IEC 27019:2024 — Sector energía: controles OT/ICS alineados a 27002:2022:
 - Revisión mayor: integra 27002:2022 y operaciones OT/ICS.
 - Controles para telemedida, despacho, telecontrol y comunicaciones industriales.
 - Acción: refrescar matriz de controles y pruebas en campo.
- ISO/IEC 27033-7:2023 — Redes virtualizadas/SDN/NFV:
 - Guía para SDN/NFV y microsegmentación; nuevos vectores de riesgo en funciones virtualizadas.
 - Acción: revisar arquitectura de red, políticas, hardening y monitoreo en entornos virtuales/cloud.
- ISO/IEC 27035-1/-2:2023 — Gestión de incidentes: proceso y preparación reforzados:
 - Parte 1 (2023): principios y proceso; Parte 2 (2023): preparación y lecciones

aprendidas; Parte 3 (2020): operación.

- Acción: PRI por fases, ejercicios periódicos, KPIs (MTTD/MTTR) y coordinación con forense digital.
- ISO/IEC 27031:2025 — Preparación TIC para continuidad (sustituye 27031:2011 y consolida retirada de 24762):
 - Nueva edición que actualiza preparación TIC para continuidad y DR.
 - Acción: inventario de servicios críticos, pruebas por RPO/RTO y runbooks integrados con seguridad.
- ISO/IEC 27001 Amd 1:2024 — Contexto y partes interesadas deben contemplar cambio climático:
 - Se refuerza la consideración del cambio climático en 4.1 y 4.2.
 - Acción: evidenciar en análisis de contexto, partes interesadas, riesgos y continuidad.
- ISO/IEC 38500:2024 — Gobierno de TI modernizado.

4. Gobernanza de IA: 42001, 23894 y 42005

- ISO/IEC 42001:2023 — Sistema de Gestión de IA (SGIA).
- ISO/IEC 23894:2023 — Gestión de riesgos de IA en el ciclo de vida.
- ISO/IEC 42005:2025 — Evaluación de impacto en personas y sociedad.
- Acción: definir alcance, roles, trazabilidad de datos/modelos y evaluación de impacto ético-social.

5. Checklist de transición y acciones inmediatas

Guía de auditoría interna para cerrar brechas al migrar a las ediciones vigentes:

27001:2022 + Amd 1:2024

- Actualizar análisis de contexto para incluir riesgos y oportunidades derivados del cambio climático.
- Revisar partes interesadas y obligaciones relacionadas; evidenciar decisiones.
- Ajustar evaluación de riesgos y continuidad con escenarios extremos.

27018:2025 & 27701:2019

- Revisar acuerdos con proveedores cloud y cláusulas de encargado/subencargado.
- Validar registro de actividades, logs de acceso a PII y cifrado.
- Actualizar evaluación de transferencias internacionales y derechos del interesado.

27019:2024 (energía) & 27033-7:2023 (redes virtualizadas)

- Actualizar matriz de controles para OT/ICS y teleoperación.
- Revisar segmentación, microsegmentación y políticas en SDN/NFV.
- Probar escenarios de fallo en redes virtualizadas y dependencias con cloud/edge.

27035 (2023/2020) & 22301:2019

- Reestructurar el Plan de Respuesta a Incidentes por fases y funciones.
- Programar ejercicios periódicos (table-top y técnicos) y registrar lecciones aprendidas.
- Alinear la comunicación de crisis con continuidad y stakeholders.

27031:2025

- Inventariar servicios críticos TIC y dependencias (SaaS/PaaS/IaaS).
- Diseñar pruebas de recuperación por objetivos RPO/RTO realistas y medibles.
- Integrar runbooks de DR con ciberseguridad y proveedores externos.

31000:2018 & 31073:2022

- Alinear definiciones y taxonomía de riesgo en todas las políticas.
- Revisar apetito y tolerancias de riesgo aprobadas por alta dirección.
- Mantener evidencias de monitoreo y revisión periódica.

38500:2024

- Actualizar el modelo de gobierno de TI (roles, comités, reporting).
- Incluir supervisión de datos, ciberseguridad y uso responsable de IA.
- Alinear KPIs/KRIs y métricas de valor con el negocio.

42001:2023, 23894:2023 y 42005:2025

- Definir alcance del SGIA, propietarios de modelos y trazabilidad de datos.
- Incorporar evaluación de impacto de IA (ética-social) y conectarla con DPIA cuando aplique.
- Establecer controles de seguridad, trazabilidad y explicación según el riesgo del sistema.

6. Nueve movimientos inmediatos

- Actualizar contexto y partes interesadas (27001+Amd1).
- Revisar contratos y evidencias con CSP (27018:2025, 27701).
- Alinear OT/ICS y redes virtuales (27019:2024, 27033-7:2023).
- Refactorizar PRI y ejercicios (27035).
- Migrar DR/BCP TIC a 27031:2025.
- Sincronizar metodología de riesgos (31000, 31073, 27005).
- Refrescar gobierno de TI (38500:2024).
- Desplegar SGIA y evaluación de impacto (42001/23894/42005).
- Evidenciar todo en auditorías internas (plan anual).

7. Notas metodológicas y alcance

Documento orientado a responsables de GRC, Compliance, CISOs, DPOs, Abogados tecnológicos, ingenieros y equipos de consultoría y auditoría. No sustituye a la lectura de los textos normativos; su objetivo es operativo y de planificación.

Estado de las normas: consolidado a septiembre de 2025. Algunas normas podrían encontrarse en revisión (DIS/FDIS) sin publicación definitiva; solo se recogen ediciones finales vigentes.

8. Agradecimiento

Espero que os pueda servir de guía y ayuda y recíprocamente agradezco cualquier comentario crítico/constructivo que sirva para seguir creciendo todos a una.

Ps: Podéis encontrarme y seguirme en LinkedIn para más contenidos de GRC, Ciberseguridad, Privacidad e IA: <https://www.linkedin.com/in/jos%C3%A9-carlos-almansa-moreno/>

¡Muchas Gracias a todos!